DATAMINERS

S.G.R.S.I

Sistema de Gestión de Recursos y Soporte de Informática

Ciberseguridad

DataMiners

Rol	Apellido	Nombre	Documento de identidad
Coordinador	Pereira	Nicolas	5.741.786-8
Sub-Coordinador	Coirolo	Bruno	5.758.905-7
Integrante 1	Camacho	Francisco	5.728.405-1
Integrante 2	Larrosa	Alvaro	5.788.908-1

Docente: SINDONI, Carina

SEGUNDA ENTREGA

24 ago 2026



DATAMINERS

Índice

1. Introducción
2. Alcance de la Segunda Entrega
3. Desarrollo del Proyecto
    3.1 Objetivos de Seguridad
    3.2 Medios para el cumplimiento de los objetivos de seguridad
    3.3 Protocolo de respuesta a incidentes
    3.4 Funcionamiento de los protocolos criptográficos
    3.5 Sistemas de autenticación
4. Estado de avance acumulado (Primera Entrega)
5. Anexos
6. Referencias bibliográficas



DATAMINERS

Introducción

El presente documento constituye la segunda entrega de la unidad curricular Ciberseguridad, correspondiente al proyecto de egreso del Bachillerato Tecnológico en Informática del ITI-CETP, edición 2026.

Al ser una entrega incremental, este documento toma como base los fundamentos de seguridad y amenazas identificadas en la Primera Entrega, y avanza en la definición de los objetivos, medidas tecnológicas, protocolos criptográficos, métodos de autenticación y el protocolo de respuesta ante incidentes para el Sistema de Gestión de Recursos y Soporte de Informática (SGRSI).

Alcance de la Segunda Entrega

De acuerdo a la rúbrica del proyecto, esta segunda entrega cubre los siguientes requerimientos:

- Evaluación de los valores necesarios en el sistema para proteger los dispositivos, sistemas y datos (Objetivos de Seguridad).
- Determinación de los medios a utilizar para el cumplimiento de dichos objetivos.
- Definición del protocolo de respuesta a incidentes.
- Descripción del funcionamiento de los diferentes protocolos criptográficos.
- Características de los sistemas de autenticación a implementar en la empresa.

Desarrollo del Proyecto

3.1 Objetivos de Seguridad

En el SGRSI, se han evaluado como valores críticos a proteger: los datos personales de los usuarios, la información de los equipos tecnológicos (inventario), las incidencias técnicas/préstamos y las credenciales de acceso.

Para proteger esta información frente a las amenazas identificadas, se establecen los siguientes objetivos de seguridad informática:

Objetivos de seguridad definidos
• Confidencialidad: garantizar que solo las personas debidamente autorizadas puedan acceder a la información, mitigando ataques de robo de credenciales o accesos no autorizados.
• Integridad: asegurar que los datos registrados no puedan ser modificados ni eliminados de forma ilegítima o accidental.
• Disponibilidad: lograr que los servicios del sistema estén accesibles durante el horario de uso institucional y que existan planes de contingencia ante caídas (ej. fallas de hardware o ataques DDoS).
• Trazabilidad: registrar todas las acciones críticas realizadas en el sistema para poder identificar anomalías y responsabilidades.

3.2 Medios para el cumplimiento de los objetivos de seguridad

Para cumplir los objetivos de seguridad y proteger al SGRSI, se determinan los siguientes medios técnicos y organizativos:

Medios técnicos y organizativos aplicados
• Control de Acceso Basado en Roles (RBAC): cada usuario (Administrador, Técnico, Solicitante) operará bajo el principio de mínimo privilegio, accediendo solo a las funciones correspondientes a su rol. Esto asegura la *Confidencialidad*.

• Validación de Datos en Formularios: todo ingreso (input) será validado y sanitizado tanto en el cliente (JavaScript) como en el servidor (PHP) para evitar inyecciones de código y mantener la *Integridad*.
• Cifrado de Comunicaciones (HTTPS): protege la *Confidencialidad e Integridad* de la información sensible durante su viaje por la red.
• Copias de Seguridad (Backups) Periódicas: se ejecutarán respaldos automáticos de la base de datos MySQL en un servidor externo. Esto mitiga la pérdida de información (ej. por Ransomware) garantizando la *Disponibilidad*.
• Registro de Actividades (Logs): se guardarán en el servidor archivos de auditoría con las acciones críticas del sistema, garantizando la *Trazabilidad*.

3.3 Protocolo de respuesta a incidentes

Ante cualquier evento que comprometa la seguridad del SGRSI, el equipo DataMiners aplicará el siguiente protocolo de respuesta:

1. Detección y Análisis: se realizará un monitoreo constante de los logs del sistema (ej. /var/log/auth.log, logs de MySQL y PHP). Las detecciones anómalas (como múltiples intentos fallidos de login) abrirán automáticamente un ticket de incidente.
2. Contención:
    - *Ataques web (SQLi, Phishing):* se bloqueará inmediatamente la IP origen a través del Firewall.
    - *Credenciales comprometidas:* se deshabilitará la cuenta del usuario en la base de datos y se forzará el cierre de sus sesiones activas.
    - *Servidor comprometido:* se detendrá el contenedor Docker afectado de forma aislada sin detener toda la infraestructura.
3. Comunicación: el Técnico o soporte a cargo notificará de inmediato al Administrador/Coordinador.
4. Recuperación: una vez erradicada la amenaza, se restaurará el servicio desde el servidor de respaldo (backup íntegro de la base de datos) asegurando que no haya duplicación de datos ni fallas de integridad referencial.
5. Lecciones Aprendidas (Mejora Continua): todo incidente cerrado generará un informe documentando qué sucedió, la corrección aplicada a nivel de código o red, y la fecha.

3.4 Funcionamiento de los protocolos criptográficos

Para proteger la información en reposo y en tránsito, el SGRSI implementa los siguientes protocolos y algoritmos:

Protocolos criptográficos implementados
• Bcrypt (Cifrado de Contraseñas): las contraseñas de los usuarios no se guardan en texto plano. Se procesan con la función password_hash() de PHP utilizando Bcrypt. Este algoritmo incluye un valor aleatorio único ("salt") y repite el proceso de hash varias veces ("factor de costo"), haciendo que sea altamente resistente a los ataques de fuerza bruta y evitando que una filtración de la base de datos exponga las claves.
• TLS / HTTPS (Transmisión Cifrada): toda la comunicación entre el navegador del usuario y el servidor se cifra usando TLS. Funciona en dos etapas: primero el servidor y el cliente negocian de forma asimétrica una clave única, y luego todo el tráfico web se cifra con un algoritmo simétrico (como AES), asegurando que nadie pueda interceptar o leer los datos en tránsito.
• SHA-256 / HMAC: se utilizan funciones de hash para verificar la integridad de los datos; ante el menor cambio en un archivo o mensaje, el código resultante cambia drásticamente, lo cual es útil para verificar que los respaldos no hayan sido alterados.

3.5 Sistemas de autenticación a implementar

El SGRSI utiliza un sistema de Autenticación Obligatoria mediante Credenciales (Email institucional y Contraseña cifrada) ligado al control de sesiones y roles. Sus características son:

Características del sistema de autenticación
• Verificación Centralizada: todo módulo del sistema requiere inicio de sesión. Si un usuario no posee una sesión activa, el sistema lo redirige al formulario de Login.
• Protección contra Fijación de Sesiones: una vez que el usuario ingresa sus credenciales correctamente, el sistema regenera el identificador de sesión, invalidando cualquier identificador previo que un atacante pudiera conocer.
• Cierre Automático por Inactividad: para prevenir el robo de credenciales por error humano (ej. dejar un equipo de laboratorio abierto), las sesiones caducarán tras un período de inactividad, exigiendo volver a autenticarse.

Estado de avance acumulado (Primera Entrega)

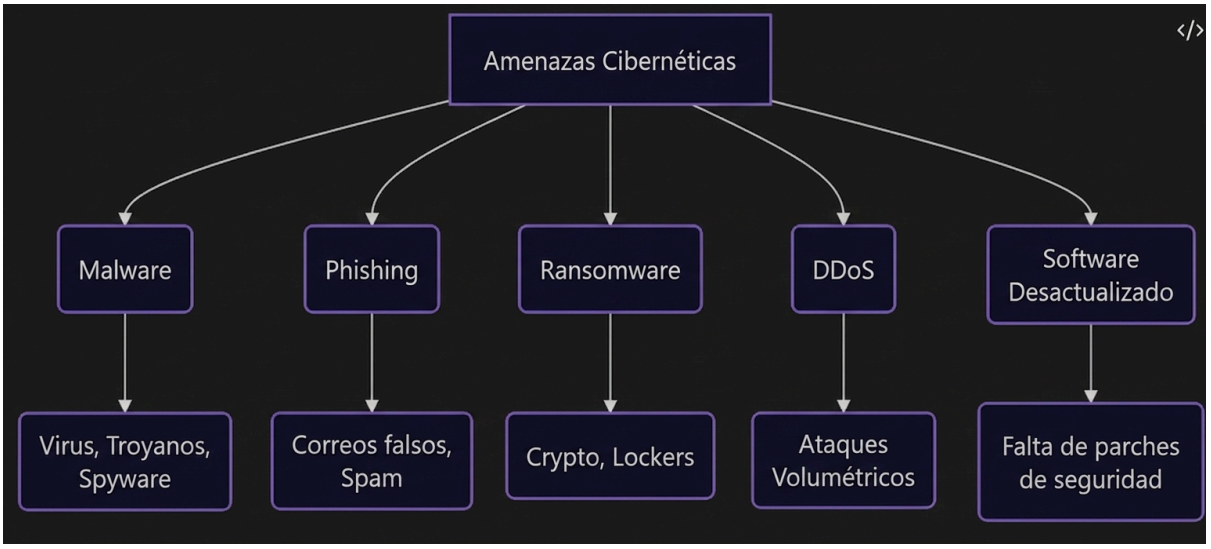
En la entrega anterior, el equipo abordó los fundamentos esenciales de la seguridad informática para el SGRSI. Se reconoció que la información gestionada (datos, equipos, incidencias) es el activo principal.

Asimismo, se construyó un mapa conceptual identificando las principales amenazas del entorno digital (Acceso no Autorizado, Robo de Credenciales, Malware, Phishing, Ransomware y DDoS). Todas las medidas, protocolos criptográficos y reglas de autenticación propuestas en esta segunda entrega están directamente diseñadas para mitigar las amenazas identificadas en la primera etapa.

Anexos

Anexo 5.1 — Mapa Conceptual de Amenazas Cibernéticas

A continuación se presenta el esquema de las principales amenazas documentadas en la primera entrega y que las medidas actuales buscan mitigar:



Anexo 5.2 — Tabla de Detección y Monitoreo de Incidentes

Fuente	Qué se monitorea	Herramienta/comando
Logs de acceso SSH	Intentos de login fallidos, IPs no habituales	/var/log/auth.log
Logs de la aplicación PHP	Excepciones no controladas, errores 500	Log de errores de PHP
Logs de MySQL	Consultas anómalas, errores de sintaxis	general_log o slow_query_log
Estado de contenedores	Caídas, reinicios inesperados, uso de CPU	docker stats , docker ps -a
Sesiones activas	Mismo usuario logueado desde distintas IPs	Tabla de sesiones / RBAC

Anexo 5.3 — Resumen de Algoritmos Criptográficos

Protocolo / Algoritmo	Fase que protege	Objetivo (CIA)	Resumen de funcionamiento
bcrypt	Almacenamiento	Confidencialidad	Genera un hash adaptativo de la contraseña con un salt único por usuario.
TLS (HTTPS)	Transmisión	Confidencialidad e integridad	Cifra el canal de comunicación entre el navegador y el servidor.
SHA-256	Almacenamiento y transmisión	Integridad	Genera una huella digital fija para detectar alteración de datos.

Referencias Bibliográficas

- Bambu Mobile. (2024). Protocolos de ciberseguridad.
- Benegas, L. (s.f.). Protocolos de seguridad informática. Prezi.
- Krawczyk, H., Bellare, M., & Canetti, R. (1997). RFC 2104: HMAC — Keyed-Hashing for Message Authentication. IETF.
- Material proporcionado por la unidad curricular y apuntes de clase del ITI-CETP.
- OWASP Foundation. (2023). Password Storage Cheat Sheet.
- Rescorla, E. (2018). RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3. IETF.